Executive Summary | Capstone Project, Group 19

An Explainable Automated Cyber-Insurance Underwriting and Continuous Monitoring Platform

Krish Mundhra (K041) | Harsh Rathod (K080) | Yugandhara Goud (K023)

Faculty Mentor: Prof. Rohit Suryawanshi | B.Tech CSE (Cybersecurity), MPSTME, SVKM's NMIMS, Mumbai | 2026-27

1. Introduction and problem statement

Cyber insurance lets a company pass part of the cost of an incident to an insurer. Indian small and medium enterprises (SMEs) face the same ransomware, email-compromise and payment-fraud attacks as large firms, yet few of them carry cover, while the CERT-In Directions (six-hour incident reporting) and the DPDP Act (penalties of up to ₹250 crore) have raised the cost of an incident. The way cyber insurance is sold has not kept pace:

- **Priced with traditional thinking.** Loss history is short and heavy-tailed, and premiums rest mainly on revenue and industry.
- **The premium is a black box.** The insured sees one number and cannot tell which answer raised it or what would lower it.
- **One questionnaire, once a year.** The policy rests on a form the company completes itself, and nobody revisits it until renewal.
- **Controls are never verified.** A self-declared "yes" is priced the same as a test result.
- **A static view of a dynamic landscape.** Nothing is checked after the policy is bound, so a gap surfaces only at claim time.

Problem statement: To design and build an explainable cyber-insurance underwriting system for Indian SMEs that grades the evidence behind each security control, prices a policy from published claims data with every factor traceable and explained, monitors the insured's endpoints after bind with a read-only agent whose reports cannot be forged or replayed, and lets monitoring change warranty states only, never the bound premium.

2. Methodology

Beretta is built as two engines that share one record of evidence.

Risk engine. Every input is stored as an observation with a source, a locator and one of four evidence strengths: DECLARED, DOCUMENTED, TESTED and TECHNICALLY_OBSERVED. For each of 15 controls the strongest, most recent evidence

wins. A read-only endpoint agent runs 12 checks and sends reports signed with HMAC-SHA256 and numbered against replay, and a build hash exposes modified agents. The collector rolls the results up per company (a control passes if at least 95% of the hosts able to observe it pass, and a silent host counts as a failure) and sends one signed roll-up to the platform.

Pricing engine. A frequency–severity model prices five perils separately: ransomware, email compromise, funds transfer fraud, other first-party loss and third-party liability. Frequencies come from Coalition's 2025 claims data, each loss is lognormal with a shape ($\sigma = 2.193$) fitted to NetDiligence SME claims, and the payout is integrated through the retention and the limit. Control effects come from Marsh McLennan (2023), and a stated control earns 60% of a verified control's credit. Claims history enters through a credibility factor ($\alpha = 4.22$). The technical premium is the expected loss divided by a 0.50 target loss ratio, with 18% GST added. Every parameter sits in one file with its source and a tag: published, derived or assumed.

Warranties after bind. Monitoring results reach a bound policy only through a warranty state machine (MET, IN_GRACE, BREACHED, REMEDIATED) with a 7- or 14-day grace period. The engine refuses to price a bound policy.

Build and test. The system uses the Python standard library and plain HTML, CSS and JavaScript, with dashboards for the underwriter, administrator and insured, and a fleet dashboard for the collector. It was validated by 224 automated tests and a live demonstration with four SIMULATED endpoints and a Windows virtual machine.

3. Key findings and results

Area	Result
Testing	All 224 automated tests pass: 65 for the platform and pricing model, 158 for the agent and collector, and 1 end-to-end test across both systems.
Evidence changes the price	For a reference firm the technical premium is ₹2,48,235 with no evidence, ₹55,342 with every control stated and ₹46,487 with every control verified.
Worked example	IT services firm, ₹150 crore turnover, ₹5 crore limit: expected loss ₹49,947, technical premium ₹99,895, payable ₹1,17,876. Verifying privileged access management alone would save ₹32,421.
Model checks	The five peril frequencies add to 1.38% (1.47% with other claims) against the published 1.48%. No single assumption moves the premium by more than about 16%.
Linked demonstration	Stopping EDR on one of four machines moved the EDR warranty to IN_GRACE within seconds, then to BREACHED, and back to MET after the fix. The bound premium stayed at ₹94,135 throughout, and a re-price was refused.

The main limitation is that the loss data is US-weighted: the India adjustment factors stay at 1 until Indian claims data is published, and several shares and adoption rates are labelled assumptions with a sensitivity range.

4. Project value and impact

- **For SMEs:** a premium they can understand, with the saving from each control shown, so security spending can be planned against cost.
- **For insurers and MGAs:** a reference design for evidence-graded underwriting with post-bind warranty monitoring, which reduces reliance on unverified answers.
- **For brokers, regulators and auditors:** a complete, reproducible pricing method in which every assumption is labelled and every quote can be reproduced from its snapshot.
- **Privacy and fairness:** the agent is read-only and collects no personal content, and monitoring never re-prices the policy; it acts through warranties with a grace period.

The opportunity is large. India has 8.84 crore enterprises on the Udyam portals, published estimates put cyber-insurance take-up among Indian companies under 5%, and the Indian market is forecast to grow about 18.4% a year against 14.2% worldwide (MarketsandMarkets). The next steps are calibration to Indian claims, identity-provider connectors to verify MFA, policy limits and payouts on the dashboard, and a pilot on real company fleets.